Note au comité des risques — Conformité DORA, Banque Ardelle

Oct 28, 2026 · @Kennedy

Objet : résultats de l'audit de conformité DORA (AUD-DORA-01) et plan d'action proposé, en vue du contrôle sur place de l'ACPR prévu au 2e trimestre 2027.

Synthèse

La Banque Ardelle n'est pas en mesure, aujourd'hui, de démontrer sa conformité à DORA : sur 95 exigences évaluées, 49 sont non conformes, dont 29 non-conformités majeures. Le problème n'est pas d'abord technique : il tient à la gouvernance du risque TIC et à la maîtrise des prestataires. Un plan de 11 mesures, chiffré à 320 k€ d'investissement et 68 k€ par an, permet de traiter les écarts majeurs avant le contrôle, à l'exception des stratégies de sortie, qui seront présentées en cours de réalisation. Le directoire est invité à prendre quatre décisions dès sa prochaine séance.

Niveau de conformité

Seules 4 % des exigences évaluées sont pleinement conformes ; la moitié est non conforme. Les deux piliers les plus exposés sont la gestion des incidents et la maîtrise des prestataires TIC.

Pilier DORA	Exigences évaluées	Conformes	Partiellement conformes	Non conformes	dont majeures
II – Gestion du risque TIC	46	4	25	17	15
III – Incidents TIC	12	0	2	10	5
IV – Tests de résilience	4	0	3	1	1
V – Prestataires TIC	33	0	12	21	8
Total	**95**	**4**	**42**	**49**	**29**

Sur les 260 exigences du règlement, 64 ne s'appliquent pas à la banque (obligations des autorités, des dépositaires centraux ou des microentreprises) et 101 n'ont pas pu être évaluées faute de preuve (voir les limites en fin de note). Points forts à souligner : authentification forte pour tous les clients, SOC opérationnel 24 h/24, tests d'intrusion annuels sur l'application mobile.

Les cinq écarts majeurs

Les 29 non-conformités majeures se ramènent à cinq causes, classées par risque pour l'activité.

#	Écart	Risque pour l'activité	Articles DORA
1	Le directoire n'a ni approuvé ni revu la politique de risque TIC depuis 2022, et le RSSI dépend du DSI qu'il doit contrôler	Responsabilité personnelle des dirigeants engagée ; premier point examiné par l'ACPR	5, 6
2	Aucune stratégie de sortie pour NovaCore (core banking) et Stratus Cloud	Une défaillance de NovaCore interromprait la tenue des comptes bien au-delà des 4 h tolérées, sans solution de repli	28, 29
3	Classification des incidents antérieure à DORA et notification à l'ACPR jamais testée	Un incident majeur pourrait ne pas être déclaré dans les délais réglementaires	17 à 19, 23
4	Sauvegardes du core banking non isolées de la production	Un rançongiciel chiffrerait à la fois la production et ses sauvegardes	12
5	Registre d'informations limité à 60 % des contrats TIC, sans droit d'audit chez deux prestataires critiques	Impossibilité de remettre un registre complet à l'ACPR ; aucun moyen de contrôler Kumo Digital et Veridex	28, 30

Plan de remédiation

Onze mesures couvrent l'ensemble des écarts. Le budget total représente environ 0,05 % du produit net bancaire annuel (610 M€).

Lot	Mesures	Échéance	Investissement	Charge interne
1 – Gouvernance (gains rapides)	Politique approuvée, RSSI rattaché aux risques, responsable des prestataires, formation du directoire	31/12/2026 – 28/02/2027	15 k€	30 j-h

Lot	Mesures	Échéance	Investissement	Charge interne
2 – Exigences critiques avant le contrôle	Sauvegardes isolées, classification et notification des incidents, registre complet	31/03/2027	140 k€	130 j-h
3 – Consolidation	Inventaire des actifs, PCA et programme de tests, renégociation de deux contrats	30/06/2027	105 k€	140 j-h
4 – Projet structurant	Stratégies de sortie NovaCore et Stratus Cloud, analyse de concentration	30/09/2027	60 k€	100 j-h
Total	**11 mesures**		**320 k€**	**400 j-h**

Coût récurrent ensuite : 68 k€ et environ 160 jours-homme par an, dont un quart de poste pour le suivi des prestataires.

Le chemin critique passe par le registre d'informations (lot 2), préalable à la renégociation des contrats puis aux stratégies de sortie. Ces dernières ne seront pas achevées lors du contrôle : la banque présentera un plan daté, financé et suivi, ce que l'autorité attend d'une entité en cours de mise en conformité.

Décisions attendues du directoire

1. **Approuver** la politique de gestion du risque TIC mise à jour et inscrire sa revue annuelle au calendrier du directoire.
2. **Rattacher** le RSSI à la direction des risques et **désigner** un membre de la direction responsable du suivi des prestataires TIC.
3. **Valider** le plan de 11 mesures et son budget : 320 k€ d'investissement et 68 k€ par an.
4. **Accepter formellement** le risque résiduel lié à NovaCore jusqu'à la livraison de la stratégie de sortie (septembre 2027), et demander un point d'avancement trimestriel au comité des risques.

Périmètre, méthode et limites

- **Périmètre** : les six fonctions critiques ou importantes de la banque, évaluées au regard du règlement (UE) 2022/2554 (DORA), hors normes techniques déléguées (RTS et ITS).
- **Méthode** : revue documentaire et entretiens de cadrage ; aucun test technique n'a été réalisé. Audit mené et tracé dans l'outil GRC CISO Assistant.
- **Limites** : 101 exigences n'ont pas pu être évaluées faute de preuve à la date de clôture, notamment la stratégie de résilience, la gestion des changements et des correctifs, et la communication de crise. Elles ne doivent pas être lues comme conformes ; une revue complémentaire est recommandée avant le contrôle de l'ACPR.
- **Note** : la Banque Ardelle est une entreprise fictive, créée pour un exercice de montée en compétence ; les montants sont des estimations d'ordre de grandeur.